



ÉTUDE DE CAS

Stratégie de gouvernance des données — Spotify

Du diagnostic de maturité à la mise en œuvre opérationnelle

Ahmed Mehdi SEMAR

Certification RNCP 38777 · Bloc 1 — Gouvernance des données

Une entreprise data-driven... et exposée



450 M+

utilisateurs actifs
(~200 M Premium)



180+

pays — autant de cadres
réglementaires et culturels



20 M€ / 4 %

du CA mondial : sanction
RGPD encourue

La donnée est le principal avantage compétitif de Spotify — mais sa croissance a dépassé la capacité d'adaptation de sa gouvernance.

Quatre tensions à résoudre



Silos & fragmentation

Chaque département gère ses données ; pas de vision 360° de l'utilisateur.



Conformité multi-juridiction

RGPD, CCPA, PCI-DSS... et au-delà, sur 180 pays aux règles différentes.



Qualité des données

Doublons, incohérences, métadonnées obsolètes : recommandations dégradées.



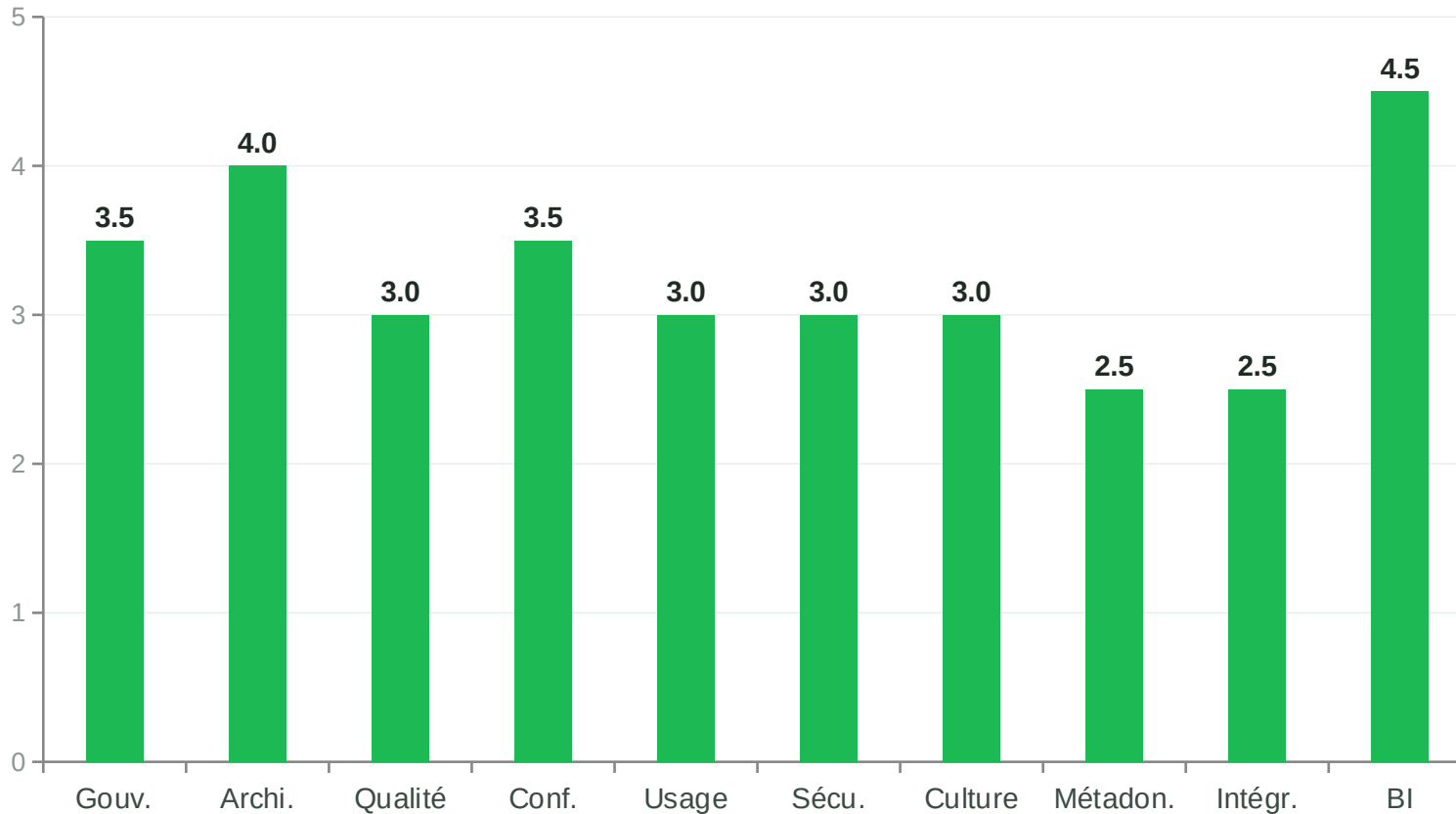
Confidentialité & accès

Concilier protection de la vie privée et accès fluide pour les équipes.

Une démarche en trois temps



Spotify exploite mieux qu'elle ne gouverne



≈ 3,2 / 5

Charnière Réactive → Proactive

Forts : analytics (4,5), architecture (4,0).

Faibles : intégration et métadonnées (2,5) — l'héritage des silos.

Enjeu : fédérer et industrialiser un existant déjà performant.

Le cadre cible : 9 principes

1 Redevabilité

2 Conformité

3 Qualité

4 Transparence

5 Minimisation

6 Droits des utilisateurs

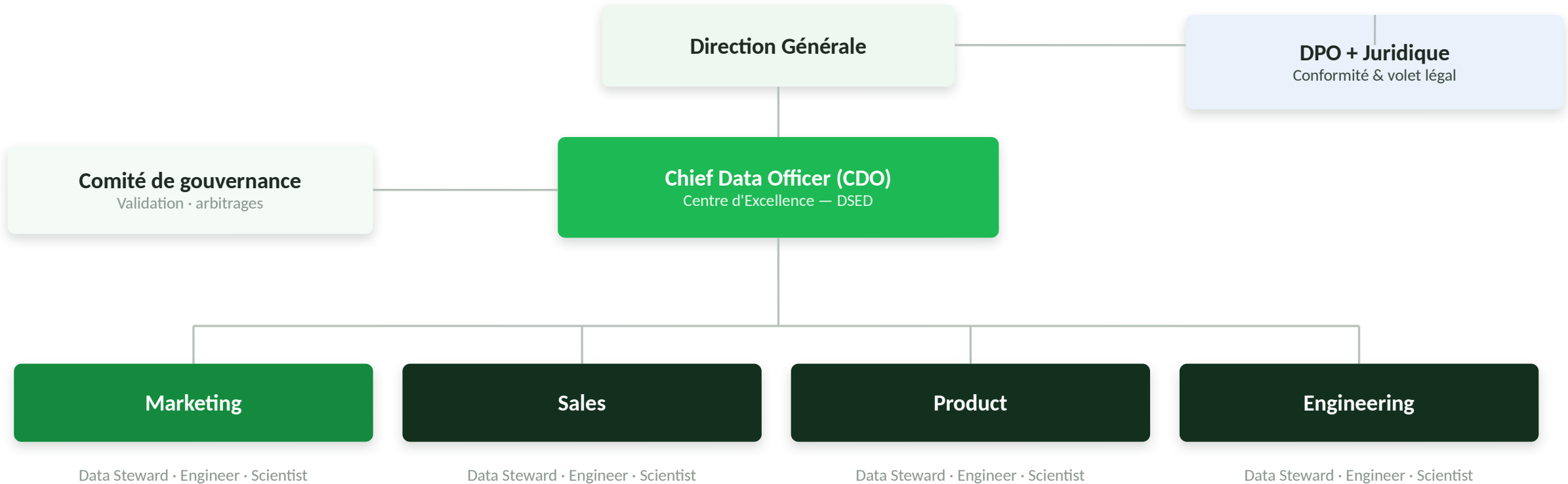
7 Sécurité

8 Usage éthique

9 Amélioration continue

Cinq axes couverts : conformité · qualité · sécurité · confidentialité · disponibilité — appliqués à toutes les données, régions et systèmes.

Un modèle fédéré : le Centre d'Excellence



Standards, outils et conformité au centre · propriété et production des données dans les domaines. Le pilote démarre sur le Marketing.

Une conformité par juridiction



RGPD

UE — appliqué par défaut

Consentement explicite, droits des personnes, notification sous 72 h.



CCPA

Californie / USA

Droit de savoir, supprimer, refuser la vente, non-discrimination.



PCI-DSS

Données bancaires

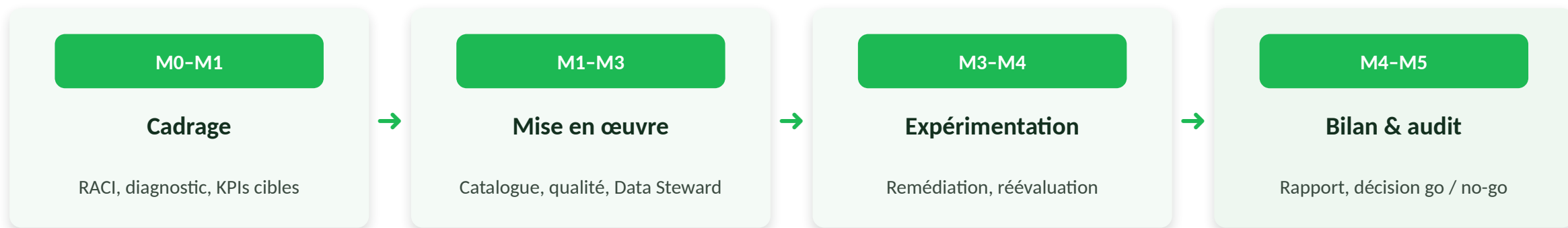
Chiffrement et protection des données de cartes de paiement.

+ Ouverture internationale

PDPA (Singapour), LGPD (Brésil), PIPEDA (Canada), IA Act, DSA... **Règle du texte le plus protecteur** et application automatisée par zone, avec veille réglementaire active.

Prouver la valeur : pilote Marketing

Pourquoi le Marketing ? fort consommateur de données utilisateurs, exposé à la qualité (profils) et au consentement — des gains rapides et mesurables.



Indicateurs de succès



Former tous les collaborateurs — sans exclure



Parcours différenciés

- **Dirigeants & sponsors**

Enjeux, valeur et lecture des indicateurs

- **Métiers (marketing, produit...)**

Qualité « by design », bases légales, consentement

- **Profils techniques**

SLO, contrôles, lineage, sécurité et masquage des PII



Inclusivité & accessibilité

- Supports conformes RGAA / WCAG 2.1 AA
- Sous-titrage, transcription, versions audio
- Documents gros caractères, lecteurs d'écran
- Salles accessibles PMR, aménagements sur demande
- E-learning + ateliers + onboarding

Piloter dans la durée : audits & risques

Audits récurrents

Trimestriel

Qualité, sécurité, métadonnées (SLO, accès, lineage)

Semestriel

Conformité : registre, DSR, consentement, transferts

Annuel

Multi-juridiction + audit externe, veille réglementaire

Registre des risques (extrait)

Risque	Criticité	Mitigation
Doublons / incohérences	Élevé	SLO, tests, MDM
Non-conformité multi-juridiction	Très élevé	Règles par zone, OneTrust
Accès non autorisé (PII)	Très élevé	RBAC/ABAC, chiffrement
Résistance au changement	Élevé	Sponsoring, quick wins

Chaque audit → rapport au comité + plan de remédiation tracé pour le régulateur.

Bénéfices attendus & passage à l'échelle

Conformité

Risque de sanction maîtrisé,
confiance renforcée

Qualité

Données fiables = meilleures
recommandations

Efficacité

Silos résorbés, accès self-service
gouverné

Culture

Collaborateurs formés, gouvernance
partagée

Du pilote au déploiement

Après le go du pilote Marketing, déploiement par vagues — **Sales → Product → Engineering** — en réutilisant standards, catalogue et parcours de formation.

Sponsoring exécutif

Quick wins mesurés

Réutilisation

Amélioration continue

En synthèse

Un diagnostic lucide, une politique complète, un déploiement maîtrisé.

Faire passer Spotify d'une gouvernance réactive à une gouvernance pilotée — sans brider l'innovation.

Merci de votre attention — vos questions

Ahmed Mehdi SEMAR · Certification RNCP 38777 · Bloc 1